

PULSE Instrument Cluster

Cybersecurity Concept, preliminary (ISO/SAE 21434, UNECE R155)

Ahmed Abdelghany

2026-09-03

Contents

Document control	1
Change log	1
1. Purpose and proportionality	2
2. Item and trust boundaries (CS-2)	2
3. Assets	3
4. Preliminary threat analysis and risk assessment (CS-1)	3
5. Controls and the development-configuration deviations	4
6. Update concept (CS-10)	5
7. Cybersecurity requirements	5
8. Verification in the regression suite (CS-11)	7

Document control

Field	Value
Document ID	PULSE-SEC-001
Title	Cybersecurity Concept, preliminary
Version	0.9.2
Status	Skeleton for sprint 1 review; not security-reviewed
Date	2026-09-03
Author	Ahmed Abdelghany
Reviewer	Security manager, not yet assigned
Review gate	Sprint 1 review for structure; sprint 2 review for content
Parent	PULSE-SyRS-001
Related	PULSE-StRS-001, PULSE-SAD-001, PULSE-SAF-001, PULSE-RTM-001

Change log

Version	Date	Author	Change
0.9	2026-09-03	A. Abdelghany	First skeleton: item and trust boundaries, assets, preliminary TARA, controls, development-configuration deviations, update concept outline, CS-1 to CS-11 with status
0.9.1	2026-09-03	A. Abdelghany	Threat map and update-flow diagrams added; trust-boundary diagram moved to draw.io

Version	Date	Author	Change
0.9.2	2026-09-03	A. Abdelghany	CS-9 and CS-11 status updated for the regression suite

1. Purpose and proportionality

The stack is a broker on an internal network with two consumers, two providers and one camera-based sensor. The security work is proportionate to that. The goal is the same as for safety: produce the artefacts a programme would need under ISO/SAE 21434 and UNECE R155, and remove the shortcuts that only exist because this runs on a desk.

Nothing in this document has been reviewed by a security manager. Ratings are the project engineer's proposals.

2. Item and trust boundaries (CS-2)

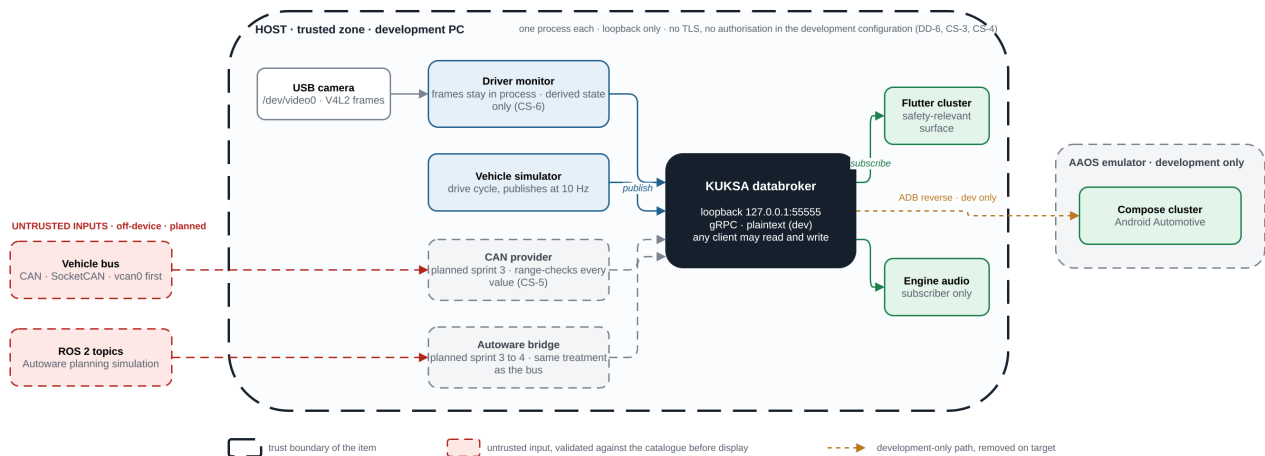


Figure 1: Item and trust boundaries in the development configuration, with the planned untrusted inputs.

Source: docs/diagrams/pulse-trust-boundaries.drawio (edit in draw.io, re-export with scripts/build-docs.sh).

Boundary	On-device or off-device	Trust today	Trust target
Broker gRPC endpoint	On-device, loopback only	Anyone on the host can read and write	Mutual TLS, per-client write authorisation (CS-3, CS-4)
Camera	On-device	Trusted input; frames stay in process	Same; add tamper and covering detection as backlog
Vehicle bus	Off-device (planned)	Not present	Untrusted; every decoded value range-checked (CS-5)
Autonomy stack	Off-device (planned)	Not present	Untrusted; same treatment as the bus
ADB reverse to the emulator	Development only	Trusted	Removed on target; the Android surface reaches the broker over an authenticated channel
Container image registry	Off-device	Image pulled at tag latest	Pinned digest, verified (CS-8)

3. Assets

Asset	Property to protect	Damage scenario
Safety-relevant signals (speed, gear, alert, intervention)	Integrity, availability	Driver misled; unintended manoeuvre
Signal catalogue (vss_agl.json)	Integrity	Broker serves a tampered tree; range checks bypassed
Camera frames	Confidentiality	Driver surveillance; privacy breach
Driver-state signals	Confidentiality, integrity	Personal data leakage; spoofed drowsiness
Broker configuration and credentials	Confidentiality, integrity	Unauthorised control of the signal path
Software artefacts (bundle, APK, container image)	Integrity, authenticity	Malicious update
Third-party dependencies	Integrity	Supply-chain compromise

4. Preliminary threat analysis and risk assessment (CS-1)

Attack feasibility per ISO/SAE 21434 annex: high, medium, low, very low. Impact: severe, major, moderate, negligible. Risk 1 to 5 from the standard's matrix.

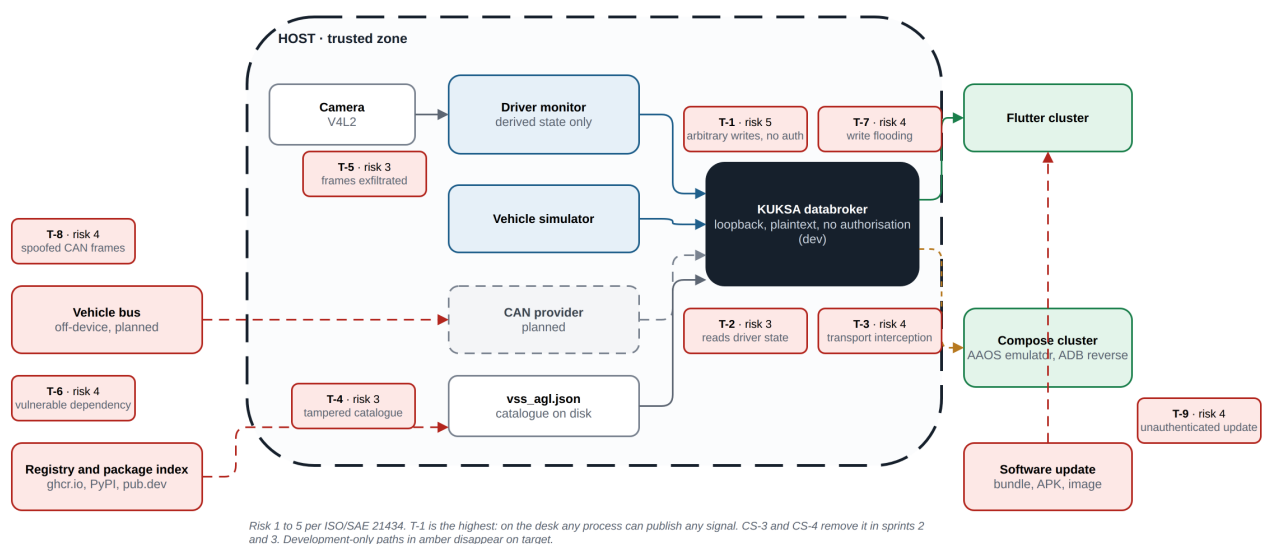


Figure 2: The nine threat scenarios placed on the architecture, with their risk values.

Source: docs/diagrams/tara-map.drawio.

ID	Threat scenario	Asset	Feasibility today	Impact	Risk	Treatment
T-1	A process on the host publishes arbitrary values for speed or alert state to the broker	Safety-relevant signals	High (no authentication, no authorisation)	Severe	5	CS-3, CS-4: authenticate clients, authorise writes per client
T-2	A process on the host subscribes to driver-state signals	Driver-state signals	High	Moderate	3	CS-3: authenticated transport; read scoping is backlog

ID	Threat scenario	Asset	Feasibility today	Impact	Risk	Treatment
T-3	Interception or modification of gRPC traffic	Signals	Low on loopback; high once off-device	Severe	4 at target	CS-3: mutual TLS before any off-device client
T-4	Tampered signal catalogue mounted into the broker	Catalogue	Medium (file on disk, read-only mount)	Major	3	CS-8, CS-9: catalogue checksum in the regression suite; FR-3 reproducibility
T-5	Camera frames exfiltrated or persisted by a modified driver monitor	Camera frames	Low	Severe (privacy)	3	CS-6: code review and a test that no file is written; process has no network beyond loopback
T-6	Malicious or vulnerable dependency (Python package, Dart package, container image)	Dependencies	Medium (latest tag, no SBOM)	Major	4	CS-8: pinned digests, SBOM, vulnerability check
T-7	Flooding the broker with writes to starve subscribers	Availability	High	Major	4	CS-4 limits writers; rate limiting is backlog; staleness detection (SR-4) keeps the display honest
T-8	Spoofed CAN frames on the bus once the CAN provider exists	Safety-relevant signals	Medium on a physical bus	Severe	4	CS-5: range and plausibility checks; bus-level security is outside the item
T-9	Unauthenticated software update replaces the cluster bundle	Artefacts	Medium	Severe	4	CS-10: signed packages, rollback on failure

5. Controls and the development-configuration deviations

Control	Requirement	State today	Removal of the shortcut
Transport encryption and client authentication	CS-3	Broker started with --insecure, loopback only. The choice is recorded here and as DD-6 in PULSE-SAD-001, satisfying IR-5	Sprint 2: enable TLS in the databroker with development certificates under certs/dev/ marked non-production; start-up prints a red warning whenever --insecure is used
Per-client write authorisation	CS-4	None; any client can set any signal	Sprint 3: KUKSA JWT authorisation with one token per provider scoped to its signal set; consumers get read-only tokens
Catalogue validation of incoming values	CS-5	Broker rejects wrong datatype, disallowed enumerations and out-of-range values on set	Sprint 2: HMI-side check as defence in depth; test that an out-of-range publish is refused
Camera data stays local	CS-6	Driver monitor never writes frames and publishes derived state only	Sprint 2: test asserting no file output and no socket other than the broker

Control	Requirement	State today	Removal of the shortcut
Security event logging	CS-7	None	Sprint 3: broker and provider logs for authentication failure, refused write, client disconnect; timestamped; no personal data
Dependency pinning and SBOM	CS-8	Python pinned in <code>requirements.txt</code> ; Dart locked in <code>pubspec.lock</code> ; container at latest; no SBOM	Sprint 2: pin the image digest; generate a CycloneDX SBOM per component; run a vulnerability check in the regression suite
No secrets in the repository	CS-9	No credentials exist; nothing to leak	Sprint 2: secret scan in the regression suite; development certificates clearly named and gitignored where private
Update concept	CS-10	None	Sprint 4: section 6 completed

6. Update concept (CS-10)

Outline, to be completed in sprint 4. UNECE R155 and R156 make this a type-approval matter, so the concept is written now and executed later.

UNECE R155 and R156 make package authenticity and failed-update behaviour a type-approval matter. Cluster, driver monitor and broker configuration form one software identification unit (RXSWIN).

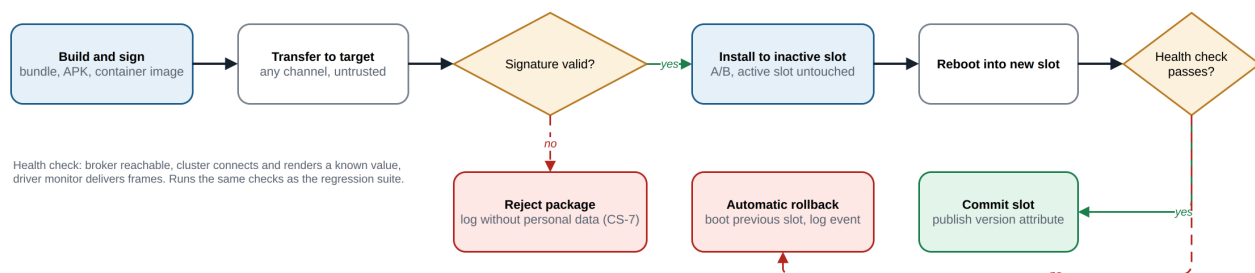


Figure 3: Update concept: signed package, A/B slot install, health check, automatic rollback.

Source: docs/diagrams/update-flow.drawio.

- Package authenticity: every deliverable (Linux bundle, APK, container image) is signed; the target verifies the signature before installation.
- Version identification: the cluster displays and publishes its software version as a VSS attribute so a fleet can be audited.
- Failed update: A/B slots on the Linux target; a failed boot after update reverts to the previous slot automatically; the Android side relies on the platform's own A/B mechanism.
- Scope of RXSWIN: the cluster, driver monitor and broker configuration form one software identification unit for R156 purposes.

7. Cybersecurity requirements

ID	Requirement	Verification	Status (W3)	Evidence
CS-1	A threat analysis and risk assessment (TARA) shall be recorded for the signal path, covering the broker, both HMI clients, the telemetry provider and the camera input, with attack feasibility rated per threat scenario (ISO/SAE 21434-15).	I	Partial	Section 4, nine scenarios; not yet security-reviewed
CS-2	The item boundary and its trust boundaries shall be documented, distinguishing on-device interfaces from anything reachable off the device.	I	Implemented	Section 2
CS-3	Broker communication shall support authenticated, encrypted transport (mutual TLS). Running without it shall be a configuration reserved for local development and flagged at start-up.	T	Planned S2	Section 5; --insecure in scripts/start-databroker.sh today
CS-4	Write access to the signal tree shall be authorised per client. A consumer shall not be able to publish, and no client shall write outside its declared signal set.	T	Planned S3	Section 5
CS-5	Signal values received from any provider shall be range- and type-validated against the catalogue before display, so a compromised provider cannot drive arbitrary content onto the cluster.	T	Partial	Broker-side validation implemented by KUKSA; HMI-side check and test in S2
CS-6	Camera frames shall not leave the device and shall not be persisted. Only derived state, such as the drowsiness level, shall be published.	I	Implemented	emulator/dms.py publishes six derived signals and writes no files; test in S2
CS-7	Security-relevant events, including authentication failure, unauthorised write attempt and client disconnection, shall be logged with a timestamp and without personal data.	T	Planned S3	Section 5
CS-8	All third-party dependencies shall be pinned and inventoried as a software bill of materials, and the inventory shall be checkable against published vulnerabilities.	T	Partial	Python and Dart pinned; container image at latest; no SBOM. S2

ID	Requirement	Verification	Status (W3)	Evidence
CS-9	No credential, key or certificate shall be committed to the repository; the development configuration shall use clearly marked non-production material.	T	Implemented	Suite check secrets scans every tracked file for key and credential patterns; passing
CS-10	An update concept shall be described for cluster and monitor software, covering authenticity of the package and behaviour on a failed update, as required for type approval under UNECE R155 and R156.	I	Planned S4	Section 6 outline
CS-11	Cybersecurity requirements shall be verified as part of the sprint regression suite, not as a separate end-of-project activity.	T	Partial	Suite exists (scripts/regression.sh) with range and secret checks for CS-5 and CS-9; CS-6 and CS-8 checks join in S2

8. Verification in the regression suite (CS-11)

From sprint 2 the regression suite run before every demo includes: catalogue checksum (T-4), out-of-range publish refused (CS-5), driver monitor writes no files and opens no socket other than the broker (CS-6), dependency vulnerability check against the SBOM (CS-8), secret scan (CS-9), and, once CS-3 lands, a check that the broker refuses a plaintext client unless the development flag is set.